INFORME DE AUDITORÍA DE SEGURIDAD

Reporte Laboratorios

OCTUBRE DE 2026

ASVS TRACKER SOFTWARE SEGURO

Índice / Tabla de Contenidos

1. Resumen Ejecutivo Pág. 3

2. Detalles Tecnicos Pág. 4

3. Gráficos de Distribución (Estado del Ticket) Pág. 5

4. Prueba de Concepto Pág. 6

5. Recomendacion de remediación Pág. 7

6. Listado Resumido y Detalle de Hallazgos (1 tickets) Pág. 8

Resumen Ejecutivo

Se identificoque el modulode ventas expone informacionconfidencialsobre el volumen de operaciones de la empresa ; debid o a un manejo inadecuadode las respuestas de error, un actorexterno no autorizadopuede enumerar y contabilizarla cantidad exacta de ventas registradasen la base de datos. Esto representa un riesgo para la confidencialidad ya que permite a la comp etencia realizar inteligenciade negociosy conocer las metricas internas de la organizacionsin necesidad de comprometer cue ntas de usuario.

Detalles Tecnicos

El endpoint GET /ventas?id=
{id} es vulnerable a una enumeracion de recursos facilitada por una referencia insegura a objetos directos (IDOR). Si bien el sistema aplica un control de acceso devolviendo un codigo HTTP 403 (Forbidden) cuando se solicita un ID de venta valido ajeno, el servidor devuelve un codigo HTTP 404 (not found) cuando el ID solicitado no existe. Esta asimetria en los codigos de estado permite automatizar peticiones mediante fuerza bruta iterando el parametro id de forma secuencial, logrando diferenciar los registros existentes de los inexistentes revelando el total de operaciones del backend.

CVSS

Distribuciónpor Estado del Ticket



CATEGORÍA	CANT.	%
Nuevo	1	100.0%

Total contabilizado : 1

Prueba de Concepto

Interceptar la peticion inicial GET /ventas/?id=1 utilizando el modulo proxy de burp suite.

Enviar la peticion capturada al modulo intruder.

En la pestaña Positions, limpiar las variables automaticas y asignar el marcador de payload unicamente al valor numerico del parametro ID (GET /ventas/?id=§1§).

En la pestaña Payloads, configurar un ataque de tipo Numbers definiendo un rango secuencial (por ejemplo del 1 al 3000)

Iniciar el ataque y ordenar los resultados haciendo clic en la columna Status code.

Identificar la fuga de informacion: el servidor devuelve un codigo 403 Forbidden para los IDs de ventas que existen en la base de datos, mientras que responde con un 404 not found para los registros inexistentes. Seleccionando todos los resultados con estado 403, es posible contabilizar el total exacto de ventas de la competencia.

Recomendacion de remediación

Implementar un control de autenticacion y autorizacion en el endpoint

Limitar los datos expuestos aplicando el principio de minimo privilegio

Validar el rol del usuario antes de permitir el acceso.

Considerar el uso de paginacion y filtros para evitar la enumeracion masiva

HALLAZGO #1 Nuevo v1.0.0

Plantilla: NoobPlantilla
Ref ID: TCK-001

TÍTULO

Exposición de información comercial mediante códigos de estado HTTP en /ventas

RESUMEN EJECUTIVO

Se identificó que el módulo de ventas expone información confidencial sobre el volumen de operaciones de la empresa; debido a un manejo inadecuado de las respuestas de error, un actor externo no autorizado puede enumerar y contabilizar la cantidad exacta de ventas registradas en la base de datos. Esto representa un riesgo para la confidencialidad, ya que permite a la competencia realizar inteligencia de negocios y conocer las métricas internas de la organización sin necesidad de comprometer cuentas de usuario.

DETALLES TECNICOS

El endpoint GET /ventas?id={id} es vulnerable a una enumeración de recursos facilitada por una referencia insegura a objetos directos (IDOR). Si bien el sistema aplica un control de acceso devolviendo un código HTTP403 (Forbidden) cuando se solicita un ID de venta válido ajeno, el servidor devuelve un código HTTP404 (Not found) cuando el ID solicitado no existe. Esta asimetría en los códigos de estado permite automatizar peticiones mediante fuerza bruta, iterando el parámetro id de forma secuencial, logrando diferenciar los registros existentes de los inexistentes revelando el total de operaciones del backend.

MÉTRICAS CVSS

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)